CAHIER DES CHARGES

Nom du projet	MedImage Trust
Équipe	Amal Ben Khalifa – Nour Ben Abdeljelil – Nourhen Toumi
Dépôt GitHub	Amal-wa/MedImage-Trust

1. Présentation générale du projet

1.1 Contexte

La plateforme assure la transmission et l'archivage sécurisés de radiographies, d'IRM et de scanners entre hôpitaux, médecins spécialistes et laboratoires de recherche. Les objets échangés sont au format DICOM (Digital Imaging and Communications in Medicine). Le projet est une PWA/SPA avec un middleware Jakarta EE 11 exécuté sur WildFly 42 / Java 25. Le métier s'organise en trois axes de dissimulation de l'information : stéganographie, watermarking et fingerprinting . Les exigences détaillées sont spécifiées dans le recueil des besoins ; les mécanismes de sécurité seront choisis lors des phases suivantes.

1.2 Problématique

Les images médicales doivent être transmises et archivées en préservant la confidentialité des données de santé, l'intégrité et la provenance des images, ainsi que la traçabilité des copies par destinataire. Les fichiers DICOM entrants constituent aussi une surface d'attaque : leur structure et leur préambule doivent être contrôlés avant tout traitement.

1.3 Objectifs du projet

Concevoir une plateforme de transmission et d'archivage sécurisés d'imagerie médicale intégrant trois services complémentaires de dissimulation de l'information.
Contrôler chaque fichier DICOM entrant et conserver l'original comme référence.
À chaque émission, régénérer la copie à partir de l'original et y appliquer trois marques : un lien patient chiffré, une preuve signée de l'intégrité et de l'origine, un code propre au destinataire.
Ne jamais compromettre l'usage diagnostique : la zone de diagnostic (ROI) n'est jamais modifiée.

1.4 Public cible et parties prenantes

Les principaux utilisateurs de l'application sont les cliniciens, les médecins spécialistes, les chercheurs, les responsables de la sécurité et les administrateurs. Chaque catégorie dispose de droits d'accès et de restrictions spécifiques, détaillés dans le recueil des besoins.

2. Présentation de la solution

2.1 Concept et principe de fonctionnement

Un professionnel autorisé importe une image DICOM. Le système vérifie sa conformité, puis conserve une copie originale dans un stockage sécurisé. Il identifie ensuite deux zones : la ROI, qui contient les informations nécessaires au diagnostic et ne doit pas être modifiée, et la RONI, qui peut accueillir les marques numériques. À chaque partage, une nouvelle copie est créée à partir de l'original et reçoit trois marques distinctes : la stéganographie (S), qui permet de cacher les données cliniques chiffrées du patient, le watermarking (W), qui permet de vérifier l'origine et l'intégrité de l'image, et le fingerprinting (F), qui permet d'identifier le destinataire de chaque copie. Pour le flux clinique, l'identité du patient est conservée dans l'en-tête DICOM. Pour le flux recherche, les informations directement identifiantes sont retirées et remplacées, si nécessaire, par un identifiant pseudonymisé. Enfin, si la zone RONI est trop petite pour accueillir les trois marques sans compromettre la qualité de l'image, le fichier est déclaré « non marquable ».

2.2 Techniques de dissimulation de l'information

Technique	Besoin couvert	Marque (partition)	Limites
Stéganographie	Conserver le lien avec le dossier du patient, même si l'en-tête DICOM est supprimé ou modifié. .	Jeton de liaison patient chiffré (S).	Les données cachées sont lisibles uniquement avec la clé de déchiffrement. La dissimulation ne constitue pas une anonymisation.
Watermarking	Prouver l'intégrité de la ROI et l'origine de l'image.	Marque numérique signée contenant l'identité de l'émetteur, les coordonnées de la ROI et les références des partitions S et W.	La ROI reste inchangée. Toute modification de la ROI doit être détectable lors de la vérification.
Fingerprinting	Attribuer une copie divulguée à son destinataire.	Code unique associé au destinataire et à la copie distribuée (F).	Le fingerprinting peut être compromis si une partie importante de l'image contenant l'empreinte est supprimée par recadrage.

2.3 Valeur ajoutée et positionnement

Valeur ajoutée. Chaque axe couvre un besoin distinct et aucun ne remplace le chiffrement ni le contrôle d'accès. Les marques restent dans les pixels quand l'en-tête est perdu. Les trois axes partagent une brique commune d'écriture et de lecture dans la RONI.

Positionnement. Le socle de sécurité s'aligne sur les standards du secteur : le profil IHE ATNA (authentification, journalisation d'audit, chiffrement) et la dé-identification DICOM PS3.15. Les marques dans les pixels complètent la signature numérique DICOM, qui vit dans l'en-tête et disparaît quand celui-ci est réécrit. Les marques dans les pixels relèvent de la recherche : une validation clinique serait requise avant tout usage réel.

3. Périmètre du projet

3.1 Fonctionnalités incluses

1. Connexion et gestion des utilisateurs : permettre aux utilisateurs de se connecter et leur donner accès uniquement aux fonctionnalités autorisées selon leur rôle.

2. Importation et archivage des images : permettre d'importer des fichiers DICOM, de vérifier qu'ils sont valides et de conserver une copie originale sans modification.

3. Création des copies sécurisées : générer une copie de l'image originale et y intégrer les trois marques (stéganographie, watermarking et fingerprinting).

4. Récupération et vérification des informations : permettre aux utilisateurs autorisés de récupérer le lien entre l'image et le dossier du patient, de vérifier que le ROI n'a pas été modifiée et d'identifier l'origine de l'image.

5. Traçabilité des copies : attribuer une empreinte différente à chaque copie distribuée

6. Gestion des images non marquables : lorsqu'une image ne dispose pas d'un espace RONI suffisant pour intégrer les trois marques sans risque, le système signale le problème et applique une procédure alternative contrôlée.

- 7. Administration et suivi : permettre à l'administrateur de gérer les utilisateurs, leurs rôles et les paramètres du système, ainsi que de consulter les alertes et l'historique des événements.

3.2 Hors périmètre

- Diagnostic médical automatisé : l'application ne réalise aucune interprétation ni détection automatique de maladies à partir des images.
- Portail et comptes patients : les patients ne pourront pas se connecter directement à l'application.
- Anonymisation par dissimulation : cacher les données personnelles dans l'image ne constitue pas une méthode d'anonymisation.

4. Architecture et environnement technique

4.1 Architecture générale

Architecture technique

L'application repose sur un navigateur professionnel (PWA/SPA React) communiquant avec les API sécurisées d'un middleware développé avec Jakarta EE 11, déployé sur WildFly 42 et exécuté avec Java 25. À la réception d'un fichier, le middleware effectue les contrôles de validité et de conformité DICOM, puis procède à l'archivage du fichier original dans MinIO, sans modification. Les métadonnées nécessaires à la gestion et à la traçabilité sont enregistrées dans PostgreSQL.

À chaque émission, une nouvelle copie de l'image originale est générée afin d'éviter toute modification de l'original. Cette copie est ensuite transmise aux services de stéganographie, de watermarking et de fingerprinting, qui utilisent une brique commune d'écriture dans la RONI (Region of Non-Interest). La copie traitée est ensuite conservée MinIO, tandis que les informations relatives aux opérations sont enregistrées dans PostgreSQL.

4.2 Technologies

Couche / composant	Technologies	Rôle
Frontend	PWA/SPA: React	Interface web des professionnels .
backend	Jakarta EE 11 / Java 25	API et services : contrôle DICOM, marquage, vérification, gestion des accès.
Serveur d'application	WildFly 42	Déploiement et exécution du backend Jakarta EE 11
Base de données	PostgreSQL	Comptes, rôles, métadonnées minimales, registre des émissions.
Stockage des fichiers	MinIO (à confirmer)	Conserve les fichiers DICOM originaux et les copies marquées
Bibliothèque DICOM	dcm4che	Lecture et écriture des objets DICOM

5. Exigences non fonctionnelles et contraintes

Catégorie	Exigence / contrainte	Critère mesurable ou vérifiable
Performance	Les temps d'importation, de marquage et de vérification doivent être évalués sur un corpus représentatif de fichiers DICOM.	Mesure de la médiane et du 95e percentile des temps d'exécution
Compatibilité	L'application PWA/SPA doit être compatible avec les navigateurs récents sur ordinateur et tablette.	Établissement d'une matrice de compatibilité des navigateurs et appareils, accompagnée de tests fonctionnels.
Ergonomie	L'interface doit distinguer clairement les opérations effectuées, les résultats obtenus, les erreurs et les avertissements, notamment en cas de fonctionnement en mode dégradé.	Validation de scénarios d'utilisation .
Maintenabilité	Les trois axes (stéganographie, watermarking et fingerprinting) doivent être développés sous forme de composants indépendants et testables, tout en partageant une brique commune d'écriture dans la RONI.	Tests unitaires de chaque service, revue de code et suivi des issues GitHub.

6. Organisation du travail

Membre	Responsabilités sur le projet
Amal Ben Khalifa	Axe stéganographie : insertion du jeton chiffré, contrôle des fichiers DICOM entrants (notamment du préambule DICOM) et régénération des copies destinées aux traitements.
Nour Ben Abdeljelil	Axe watermarking : insertion de la signature dans la ROI et la partition S, ainsi que vérification de la ROI et de la provenance de l'image.
Nourhen Toumi	Axe fingerprinting : conception et insertion des codes anti-collusion, analyse des copies suspectes et gestion du mode dégradé..
Ensemble	Mise en place de l'authentification et de la gestion des rôles, journalisation des opérations, développement de la PWA, implémentation de la brique commune d'écriture dans la RONI, segmentation ROI/RONI.

7. Planning du projet

La version actuelle clôt la phase 1. Les mécanismes de chaque exigence seront choisis lors des phases suivantes, et le recueil des besoins sera mis à jour en conséquence. Les dates restent à fixer.

Phase	Contenu
1. Spécification et conception	Cas d'utilisation, cas d'abus, cas d'utilisation de sécurité, exigences SMART, analyse des risques, justification de l'approche.
2. Confidentialité, intégrité, authenticité, disponibilité	Chiffrement du jeton, pseudonymisation, ROI immuable, signature de la preuve, régénération des copies,.
3. Authentification, autorisation, informations privées	Rôles, choix du mode d'authentification forte, verrouillage, durée de session,, séparation des tâches,
4. Journalisation et gestion des erreurs	Événements, erreurs génériques, alertes, protection du journal.
5. Tests de sécurité	DICOM piégé, XSS, force brute, exfiltration, fausse marque, échange de jetons, collusion, mode dégradé, limites des API.

Phase	Contenu
6. Déploiement et maintenance	Configuration sécurisée, gestion des clés, sauvegarde et restauration, surveillance, mises à jour.

8. Bibliographie et références techniques

1. Normes DICOM : DICOM Standard.
2. IHE ATNA : IHE – ATNA Profile.
3. INPDP : Textes juridiques de l'INPDP.
4. Loi tunisienne : Loi organique n° 2004-63.
5. dcm4che : Documentation dcm4che.
6. Jakarta EE 11 : Documentation officielle.
7. WildFly 42 : Documentation officielle.
8. PostgreSQL: Documentation officielle.
9. **Stéganographie :** Fridrich, J., *Steganography in Digital Media: Principles, Algorithms, and Applications*, Cambridge University Press, 2009. Référence bibliographique.
10. **Watermarking médical :** Qasim, A. F., Meziane, F. et Aspin, R., « Digital Watermarking: Applicability for Developing Trust in Medical Imaging Workflows – State of the Art Review », *Computer Science Review*, vol. 27, 2018. Article scientifique.

9. Glossaire

- **DICOM** : norme internationale de stockage et d'échange d'images médicales ; un fichier contient des pixels, un en-tête et un préambule de 128 octets.
- **ROI (Region of Interest)** : zone de l'image utile au diagnostic ; elle n'est jamais modifiée.
- **RONI (Region of Non-Interest)** : zone hors diagnostic, divisée en trois partitions disjointes : S (stéganographie), W (watermarking) et F (fingerprinting).
- **Stéganographie** : technique qui dissimule l'existence d'un message dans un support ; ici, le jeton de liaison patient, chiffré puis caché dans la partition S.
- **Watermarking (tatouage numérique)** : marque identique sur toutes les copies, qui prouve l'intégrité et l'origine ; ici, une preuve signée de la ROI et de la partition S.
- **Fingerprinting** : marque différente pour chaque destinataire, qui aide à attribuer une copie divulguée ; l'attribution n'est pas garantie en cas de recadrage ou de collusion au-delà des limites testées.
- **Pseudonymisation** : remplacement de l'identité par une donnée qui ne permet la réidentification qu'avec une information gardée à part (ici, la clé de l'établissement). Les données restent des données personnelles.
- **Mode dégradé** : émission, en flux clinique uniquement, d'une copie non marquée d'une image déclarée non marquable, avec avertissement, journalisation et alerte (RM05).
- **IES/SRE (Security Requirements Engineering)** : ingénierie des exigences de sécurité, c'est-à-dire la capture, l'analyse, la spécification et la gestion des exigences de sécurité. Dans ce projet, SRE ne désigne pas le Site Reliability Engineering.

- **PWA / SPA** : Progressive Web App / Single Page Application, architecture de l’interface utilisateur.